Enterprise AI governance for Copilot and every enterprise LLM

A multi-vendor enterprise AI governance programme: approved inventory, shadow AI discovery, SSO and Conditional Access, data boundaries and retention, Purview/DLP, procurement guardrails, and an AI Act/NIS2 angle — for Microsoft Copilot plus Claude, ChatGPT Enterprise, Grok and peers.

8 phases | 26 steps | Tick each item when its "done when" criterion is true

Phase 1 Set principles, owners and the approved-tools gate about 2–5 days

- [ ] **1.1 Name owners and separate product cheerleading from risk acceptance**
  Named AI risk owner, IT/security approver, data-protection contact and per-tool product owner exist in writing
- [ ] **1.2 Define the approved-tools inventory schema before the first pilot**
  Inventory columns cover identity, data classes, residency, retention, training, CA target, owner and review date
- [ ] **1.3 State the editorial and procurement gate in change control**
  Change record requires security sign-off before seats or connectors are enabled

Phase 2 Discover shadow AI and finish the inventory about 1–2 weeks

- [ ] **2.1 Discover browser and SaaS generative AI with Defender for Cloud Apps / Purview signals**
  Shadow-AI discovery report lists Generative AI / AI categories with owners assigned for triage
- [ ] **2.2 Interview product and engineering teams for API and IDE assistants**
  API keys, IDE plugins and agent platforms appear in the same inventory as chat UIs
- [ ] **2.3 Publish the first approved list and the denial list**
  Employees can see which tools are approved, conditional or denied for company data

Phase 3 SSO, IdP and Conditional Access to AI SaaS about 1–3 weeks

- [ ] **3.1 Require SSO (and SCIM where offered) before broad seats**
  Each approved Enterprise AI workspace enforces organisational SSO; consumer sign-in paths are out of scope
- [ ] **3.2 Register third-party AI apps in Entra and target them with Conditional Access**
  Report-only then enforced CA covers each in-scope AI enterprise app with MFA/auth strength and device signals as designed
- [ ] **3.3 Lock down consent, OAuth apps and agent identities**
  User consent restricted; admin consent workflow on; agent/blueprint creation rights decided
- [ ] **3.4 Apply Entra Agent ID lifecycle controls so unused agents do not linger**
  Default inactivity policy scope is reviewed; excluded seasonal agents are documented; custom policies (if licensed) are piloted against a small set first

Phase 4 Data classes, retention, residency and training boundaries about 1–2 weeks

- [ ] **4.1 Map data classes to tools — not the other way around**
  Each Approved inventory row lists allowed classifications and forbidden categories
- [ ] **4.2 Record retention, deletion and training stance per vendor product**
  Inventory cites the primary retention/training page for each approved SKU
- [ ] **4.3 Contractual pack: DPA, subprocessors, residency and audit rights**
  Signed DPA/BAA (if needed), subprocessor list review date and residency choice on file before production data

Phase 5 Purview, DLP, labels and oversharing controls about 2–6 weeks

- [ ] **5.1 Use DSPM for AI as the operational front door**
  DSPM for AI (or current DSPM experience) is owned; recommendations reviewed on a schedule
- [ ] **5.2 Sensitivity labels, encryption rights and Copilot DLP**
  Label strategy covers AI; DLP for Copilot configured where licensed; EXTRACT right understood
- [ ] **5.3 Endpoint DLP and network controls for third-party generative AI sites**
  Endpoint DLP warn/block actions cover paste/upload to unsanctioned generative AI sites for onboarded Windows endpoints

- [ ] **5.4 Insider risk, communication compliance and audit**
  Risky AI usage detections and audit search paths are documented for SOC / compliance

Phase 6 AI Act, NIS2 and literacy — operational hooks about 1–3 weeks (parallel with Legal)

- [ ] **6.1 Treat AI Act timelines as programme milestones, not blog folklore**
  Programme plan cites EUR-Lex dates and assigns Legal ownership for classification
- [ ] **6.2 Connect NIS2 cybersecurity duties where you are in scope**
  If the organisation is a NIS2 essential/important entity, AI systems used in scope inherit Article 21 risk-management expectations
- [ ] **6.3 Deliver AI literacy and human-oversight expectations**
  Training covers approved tools, data classes, hallucination risk and escalation; completion tracked for in-scope staff

Phase 7 Pilot, measure, audit and scale about Ongoing

- [ ] **7.1 Pilot per tool with success and stop criteria**
  Each pilot has seat cap, data-class limit, SSO/CA evidence, and a kill switch owner
- [ ] **7.2 Operational metrics for the AI risk owner**
  Monthly pack covers inventory freshness, shadow-AI top apps, CA coverage, DSPM open items and exception ageing

Phase 8 Troubleshoot, contain and roll back about As needed

- [ ] **8.1 Troubleshoot identity and access failures narrowly**
  Each failure mode maps to SSO, CA, consent or licence — not a blanket 'allow all'
- [ ] **8.2 Contain a suspected AI data incident**
  Incident lead can disable seats/SSO, preserve logs, and scope data classes exposed
- [ ] **8.3 Roll back a pilot or revoke a tool safely**
  Rollback runbook lists SSO off / seat revoke / CA block / connector disable / comms owner
- [ ] **8.4 Acceptance: evidence before you call the programme live**
  Signed pack: inventory, SSO/CA evidence, retention/training citations, DSPM owner, literacy, rollback

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.com/guides/enterprise-ai-governance.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.